BURP WORKBENCH KR

처음 쓰는 사람을 위한 사용 안내서

사이트의 요청을 살펴보고, 필요한 검사를 한 뒤, 결과를 저장해 봅시다.

Workbench KR은 Burp Suite에서 사용하는 웹 보안 점검 도구입니다. 예를 들어 다른 회원의 글을 읽을 수 있는지 확인하거나, 검색어를 바꿔 보면서 서버의 반응을 비교할 수 있습니다.

처음이라면 3~5쪽부터 읽으세요. 용어를 익히고 확장을 설치한 다음 요청 한 건을 확인합니다. 그 뒤에는 2쪽에서 하고 싶은 일을 골라 해당 페이지를 펼치세요. 로그인 없이 입력값 검사만 해 보고 싶다면 8쪽으로 가면 됩니다.

안내서에서 쓰는 예제	내용
확장 버전	Workbench KR 0.25.0
연습용 사이트	LOOP Community Lab 3.5.0
계정 비교 연습	Alice가 Bob의 비공개 글을 읽을 수 있는지 확인
그림 읽는 법	화면의 버튼 이름을 찾아 번호 순서대로 따라 하기

화면에서 막히면: 아래쪽 기능 안내를 누르거나 F1을 누르세요. 지금 열어 둔 기능의 설명을 볼 수 있습니다. 다른 기능을 고른 뒤 이 기능 열기를 누르면 그 화면으로 바로 이동합니다.

이 안내서의 그림은 사용법을 설명하려고 예제 데이터를 넣어 만든 화면입니다. 실제 Burp에서 점검을 마친 결과를 캡처한 그림은 아닙니다.

01 · 하고 싶은 일부터 고르세요

모든 기능을 한 번에 익힐 필요는 없습니다. 아래 표에서 하고 싶은 일을 찾고 해당 페이지부터 읽으세요.

하고 싶은 일	사용할 화면	페이지
사이트가 어떤 내용을 주고받는지 보기	요청·응답 목록	5쪽
다른 계정으로 비공개 글을 읽어 보기	계정 권한 비교	6~7쪽
검색어 같은 입력값을 바꿔 검사하기	입력값 보안 검사	8쪽
JavaScript에 적힌 서버 주소 찾기	JS에서 API 찾기	9쪽
서버 종류와 점검할 경로 확인하기	서버·경로 탐색	10쪽
점검할 주소를 더 모으기	URL 후보 수집	11쪽
아직 점검하지 않은 항목 찾기	점검 진행 현황	12~13쪽
서버 응답과 API 문서 살펴보기	응답 보안 분석	14~15쪽
저장한 내용이 다시 표시되는 곳 찾기	응답 보안 분석 → 저장/조회 연결	16쪽
읽기 어려운 값이나 두 응답 비교하기	데이터 변환·비교	17쪽
요청을 다시 보내고 증거 저장하기	재현·증거 정리	18~21쪽
점검을 마친 업무 표시하기	점검 진행 현황 → 업무별 현황	22쪽
예전 이름으로 기능 찾기	이름 비교표	24쪽

버튼을 누르기 전에: 화면을 여는 것만으로 검사가 시작되지는 않습니다. 이미 받은 응답을 분석하는 기능도 있고, 시작이나 비교 실행을 누르면 서버에 새 요청을 보내는 기능도 있습니다. 각 페이지에서 실행 순서를 확인하세요.

02 · 이 용어만 알면 시작할 수 있습니다

요청은 브라우저가 서버에 보내는 내용입니다. 응답은 서버가 돌려주는 내용입니다. 예를 들어 GET /posts/102는 “102번 글을 보여 달라”는 요청입니다. 서버는 글 내용이나 오류 메시지를 응답으로 보냅니다.

용어	뜻과 예시
URL / 메서드	요청할 주소 / 처리할 작업. GET은 주로 조회, POST는 주로 입력할 때 씁니다.
쿠키·토큰 / 세션	로그인 상태를 알아보는 값 / 그 로그인 상태입니다. 계정을 바꿔 검사할 때는 각 계정의 값을 써야 합니다.
SCOPE	이 확장에서 점검할 주소를 등록하는 목록입니다.
API	검색이나 글 조회 같은 기능을 처리하는 서버의 주소입니다.
Repeater	요청 내용을 고치고 다시 보내는 Burp 도구입니다.

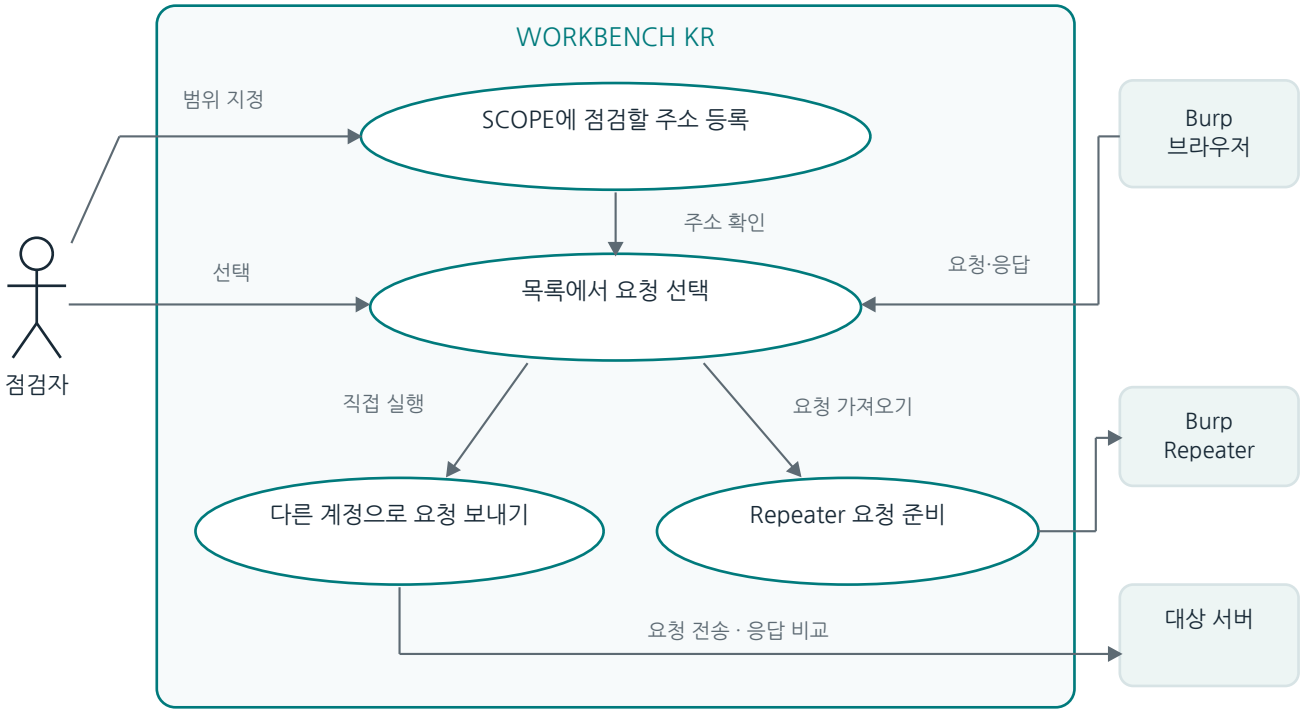


그림 1. 사용자가 요청을 고른 뒤, 계정을 바꿔 검사하거나 Repeater에서 다시 보내는 과정입니다.

응답을 읽는 요령: HTTP 200이 나와도 원하는 글이 아니라 로그인 페이지나 오류 메시지일 수 있습니다. 숫자와 본문을 함께 확인하세요.

03 · 설치하고 연습용 사이트 열기

준비물: Burp Suite, Workbench 0.25.0 JAR 파일, 실습 사이트 실행 ZIP이 필요합니다. 실습 사이트를 켜려면 Docker와 Compose v2도 설치되어 있어야 합니다.

1. 저장소의 downloads 안내에서 0.25.0 JAR 파일과 3.5.0 Docker 실행 ZIP을 받습니다. JAR는 Burp에 추가할 확장 파일입니다.

2. Burp에서 기존 Workbench를 해제합니다. Extensions → Add → Java를 선택하고 새 JAR 파일을 추가합니다.

3. Docker를 켠 뒤 실습 ZIP을 새 폴더에 풉니다. Windows는 start.ps1, Linux/macOS는 sh start.sh를 실행합니다.

4. 사이트가 준비되면 Burp 브라우저에서 http://127.0.0.1:8088을 엽니다. 요청이 멈춰 있으면 Burp의 Intercept를 Off로 바꾸세요.

확인할 결과: Burp에 Workbench KR · 웹 보안 점검 탭이 생기고, 브라우저에는 LOOP 커뮤니티가 보여야 합니다.

잘 안 되면	확인할 내용
JAR를 받았는데 웹페이지가 저장됨	GitHub 파일 화면에서 Download raw file로 다시 받으세요.
확장을 추가할 수 없음	Extensions의 오류 메시지와 받은 JAR 버전을 확인하세요.
사이트가 열리지 않음	Docker가 켜져 있는지, 다른 프로그램이 8088 포트를 쓰는지 확인하세요.
처음 실행할 때 오래 걸림	필요한 파일을 내려받는 중일 수 있습니다. 실행 창의 진행 상황을 확인하세요.

직접 명령을 입력한다면 시작은 docker compose up -d --build --wait --wait-timeout 900, 상태 확인은 docker compose ps, 종료는 docker compose down입니다. down -v를 사용하면 실습 데이터도 삭제됩니다.

이제 5쪽에서 요청 한 건을 확인해 보세요.

04 · 첫 요청 한 건 확인해 보기

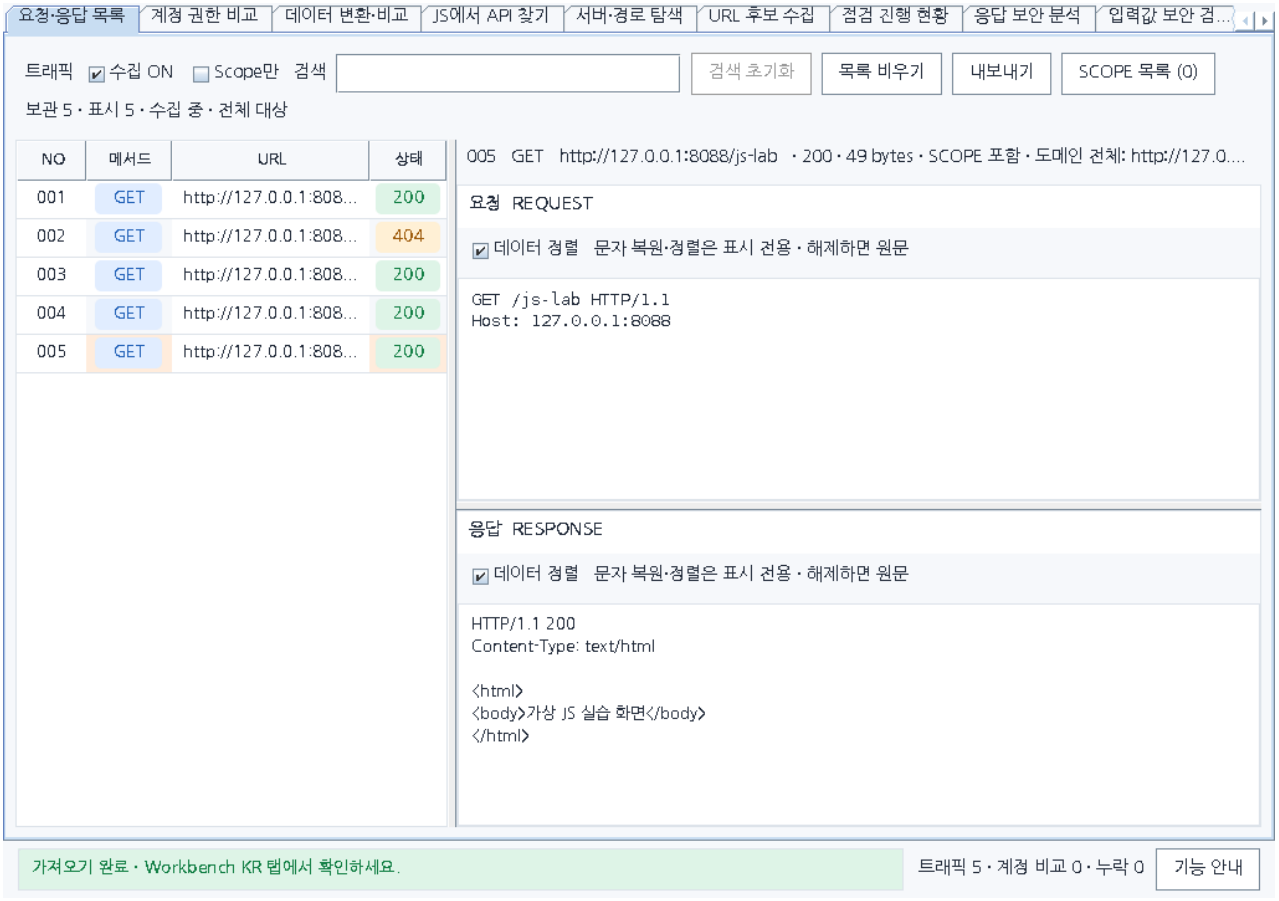


그림 2. 목록에서 요청 한 건을 고르면 그 요청과 서버의 응답을 함께 볼 수 있습니다.

1. Burp 브라우저에서 연습용 사이트의 게시글을 엽니다. 요청·응답 목록에서 방금 연 글의 주소를 선택하세요.

2. 선택한 행을 우클릭하고 SCOPE 지정 → 현재 사이트 전체 경로 추가를 누릅니다. SCOPE 목록에서 http://127.0.0.1:8088이 등록됐는지 확인하세요.

3. 선택한 요청과 응답을 읽습니다. 어떤 주소로 요청했는지, 서버가 글 내용이나 오류 중 무엇을 돌려줬는지 확인합니다.

4. 요청을 고쳐서 다시 보내려면 우클릭 → Repeater에 요청 준비를 누르세요. Burp Repeater 탭에서 내용을 확인한 뒤 Send를 누릅니다.

확인할 결과: Repeater에 새 요청 탭이 생깁니다. 요청을 넘기는 단계에서는 전송하지 않으며, Send를 눌러야 서버에 보냅니다.

목록이 비어 있다면: Burp History에서 응답이 있는 요청을 선택하고 Workbench KR → 요청·응답 목록에 가져오기를 누르세요. 실습 주소는 127.0.0.1로 맞춥니다. localhost는 이 확장에서 다른 주소로 구분합니다.

여기서 등록하는 SCOPE는 Workbench용입니다. Burp의 Target Scope와는 별도로 관리합니다.

05 · 비교할 두 계정으로 로그인하기

다음 페이지에서는 Alice가 Bob의 비공개 글을 읽을 수 있는지 비교합니다. 두 계정의 로그인을 따로 유지하려고 Repeater에서 각각 로그인합니다. 실습 계정의 비밀번호는 모두 LabOnly!2026입니다.

1. Burp 브라우저로 한 번 로그인하세요. History에서 POST /api/auth/login 요청을 Repeater로 보내고 탭 이름을 Bob 로그인으로 정합니다.

2. 요청의 Cookie 헤더를 통째로 지웁니다. 이전 로그인 값을 쓰지 않으려는 것입니다. 본문을 아래처럼 바꿔 Send를 누릅니다.

```
username=bob&password=LabOnly%212026
```

3. 응답의 Set-Cookie: JSESSIONID=...에서 = 뒤부터 첫 ; 앞까지 값을 복사합니다. 원래 로그인 요청을 새 Repeater 탭으로 보내 Alice도 로그인하세요. 본문은 username=alice&password=LabOnly%212026입니다. 두 값을 따로 보관합니다.

4. 로그인한 사람이 맞는지 확인합니다. 요청을 아래처럼 GET으로 바꾸고 본문과 Content-Length를 지웁니다. Cookie에 Bob의 값을 넣어 Send한 뒤, 별도 탭에서 Alice의 값으로도 확인합니다.

```
GET /api/auth/me HTTP/1.1
Host: 127.0.0.1:8088
Cookie: JSESSIONID=복사한값
```

5. 응답에서 Bob의 ID는 2, Alice의 ID는 1인지 확인하세요. 두 확인 요청을 요청·응답 목록에 가져오기로 Workbench에 넣습니다.

확인할 결과: 계정 권한 비교의 인증 후보 목록에 두 계정의 쿠키가 나타납니다. 이 목록은 요청에서 찾은 로그인 값을 보여 줍니다. 로그인 응답만으로는 등록되지 않으므로, 확인 요청까지 가져와야 합니다.

쿠키를 섞지 마세요. 다음 페이지에서 각 값을 비교 계정에 지정합니다.

06 · 계정을 바꿔 같은 글 읽어 보기

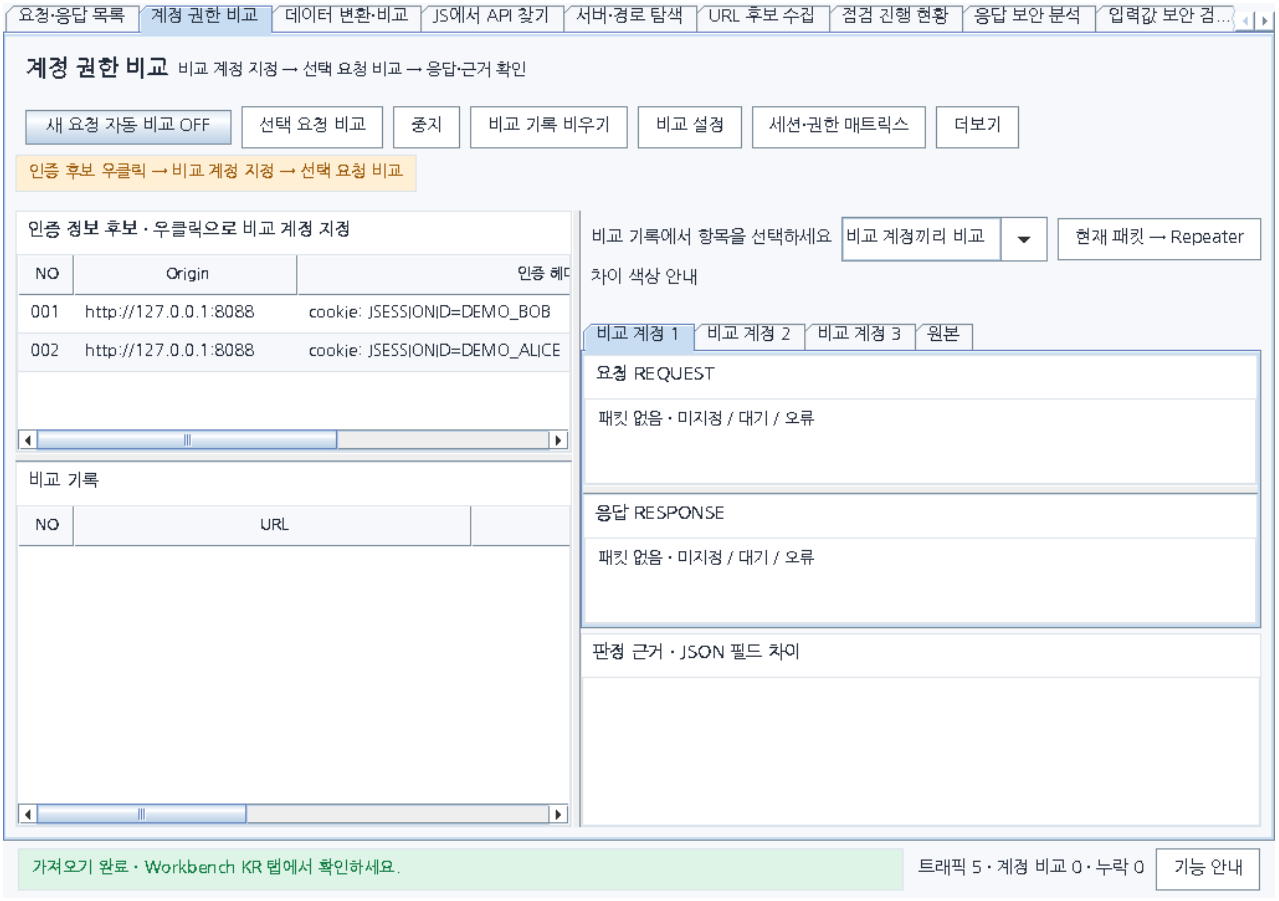


그림 3. 같은 요청을 Alice와 Bob의 로그인 값으로 보내 결과를 비교합니다.

1. Alice의 쿠키가 있는 후보 행을 우클릭하고 비교 계정 1 → 선택 후보 지정을 누릅니다. Bob은 비교 계정 2에 지정하세요.

2. 비교 설정에 이름 Alice/Bob, 소유값 1/2, 소유 JSON 경로 $.OWNER_ID를 넣습니다. JSON 경로는 응답에서 글 주인의 ID를 읽는 위치입니다.

3. 세션·권한 매트릭스에 GET /api/community/fixed/posts/102 DENY ALLOW UNKNOWN을 넣습니다. Alice는 읽으면 안 되고(DENY), Bob은 읽을 수 있어야 한다(ALLOW)는 기준입니다. 세 번째 계정은 쓰지 않습니다.

4. Bob의 쿠키로 위 주소를 Repeater에서 보내세요. 응답이 있는 요청을 Workbench에 가져와 선택한 뒤 선택 요청 비교를 누릅니다.

확인할 결과: fixed는 취약점을 고친 예제입니다. Bob은 200과 글 내용을 받고, Alice는 404를 받아야 합니다. Bob의 응답 본문에서 OWNER_ID가 2인지도 확인하세요.

취약한 예제도 비교하기: 주소의 fixed를 vuln으로 바꾸고 같은 권한 기준을 등록해 비교하세요. Alice도 Bob의 비공개 글을 읽을 수 있는 예제입니다.

처음에는 새 요청 자동 비교 OFF 상태로 한 건씩 비교하세요. 결과 저장은 20쪽에서 설명합니다.

07 · 검색어를 바꿔 서버 반응 살펴보기

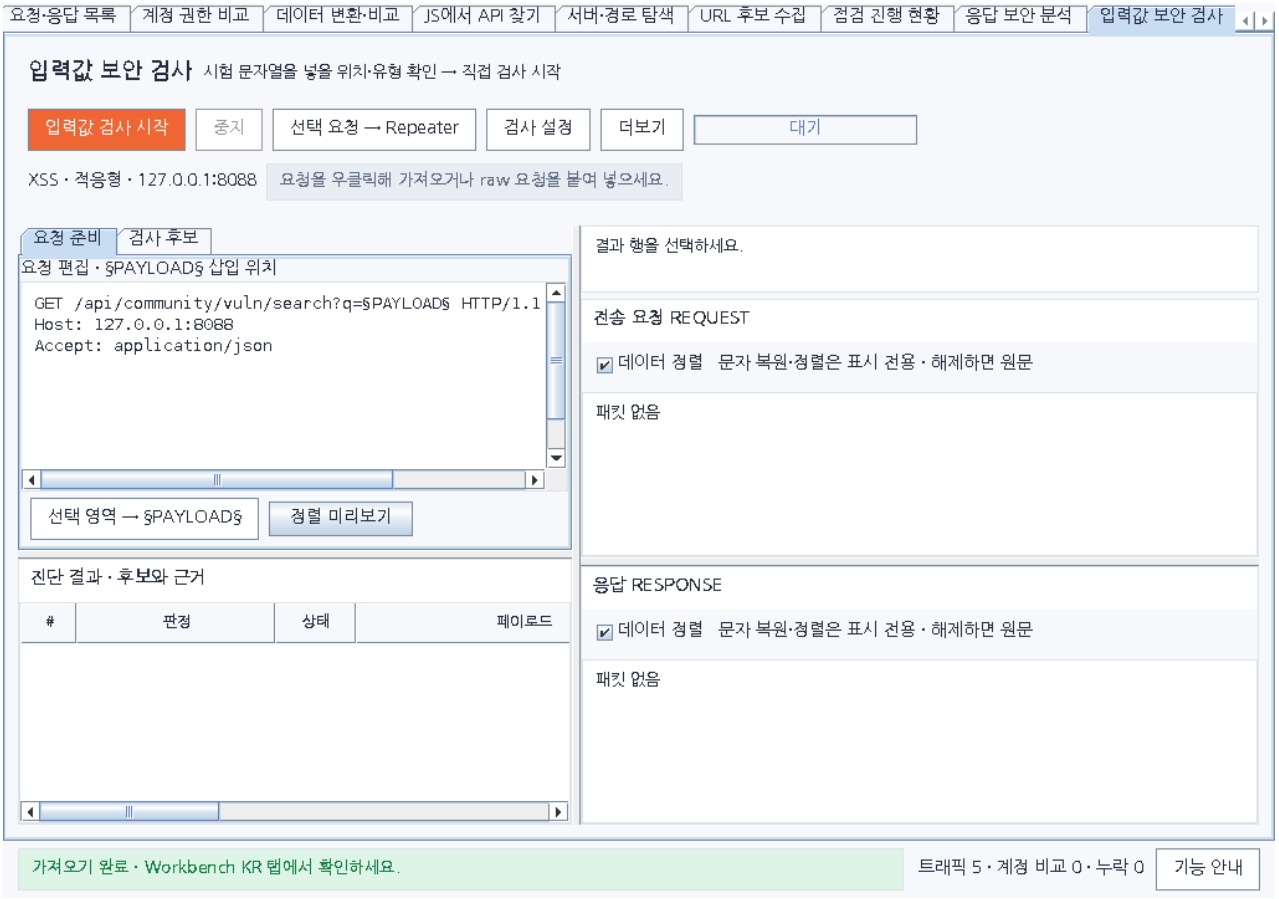


그림 4. 검사할 입력값 한 곳을 정한 뒤, 그 값을 바꿔 가며 서버 응답을 비교합니다.

이 예제는 검색어에 SQL Injection 검사값을 넣어 봅니다. SQL Injection은 입력값이 데이터베이스 명령에 영향을 주는 문제입니다.

1. 실습 주소 /api/community/vuln/search?q=normal을 엽니다. 요청·응답 목록에서 이 요청을 우클릭하고 입력값 검사에 요청 연결을 누르세요.

2. 요청 준비에서 검색어 normal만 선택하고 선택 영역 → §PAYLOAD§를 누릅니다. 선택한 자리에 검사값이 들어갑니다. 다른 값이나 쿠키는 바꾸지 않습니다.

3. 검사 설정에서 SQL Injection, URL 인코딩, 기준값 normal, 총 한도 12로 설정합니다. 기준값은 원래 검색어이고, 한도는 보낼 요청 수의 상한입니다. 유형 설명도 읽어 보세요.

4. 입력값 검사 시작을 누릅니다. 결과 행을 선택해 원래 검색어의 응답, 검사값을 넣은 응답, 결과를 확인하기 위한 비교 응답을 읽습니다. 멈추려면 중지를 누르세요.

확인할 결과: 보낸 요청 수, 응답 상태, 걸린 시간과 판단 이유가 나옵니다. 응답이 달라졌다고 바로 취약점으로 결론 내리지는 마세요. 로그인 만료나 일시적인 지연도 차이를 만듭니다.

결과를 남긴 뒤 다음 검사로: 더보기 → 검사 결과 → 증거 묶음에 먼저 담습니다. 그다음 /api/community/fixed/search?q=normal을 같은 설정으로 검사해 비교하세요. 새 검사를 시작하면 이전 결과 화면이 비워집니다. 증거 묶음에는 최대 32개를 담을 수 있습니다.

08 · JavaScript에서 서버 주소 찾기

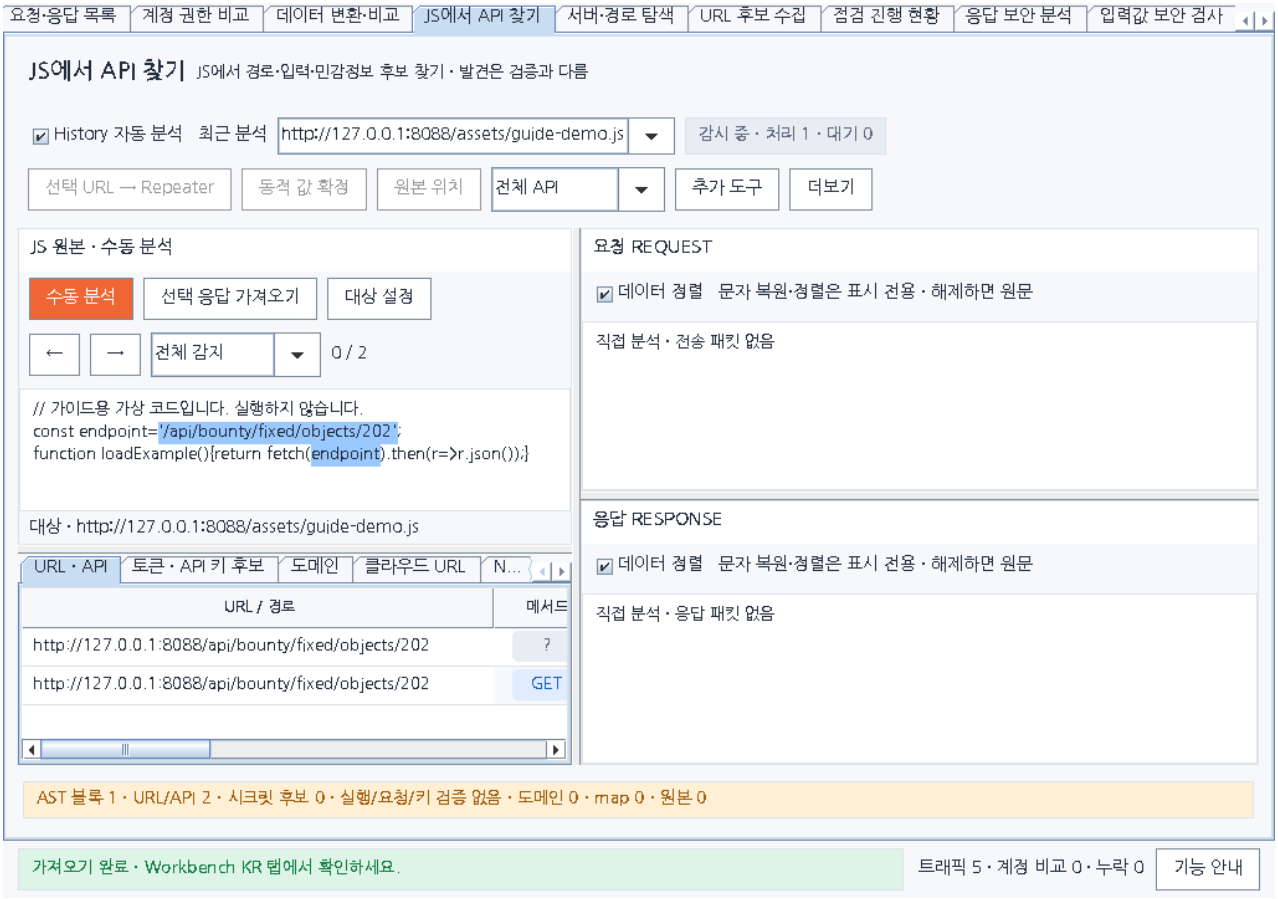


그림 5. JavaScript에 적힌 주소를 찾고, 원래 코드의 위치를 확인하는 화면입니다.

웹페이지의 JavaScript에는 화면에 보이지 않는 API 주소가 들어 있기도 합니다. 여기서는 그 주소를 찾아 점검할 항목을 늘립니다.

1. 실습 사이트의 /js-lab을 열고 전체 수집을 누르세요. 하나만 가져오려면 샘플을 선택해 단일 수집을 누릅니다. 먼저 사이트를 Workbench SCOPE에 등록해야 합니다.

2. JS에서 API 찾기에서 최근 분석 출처를 선택하고 URL · API 결과를 봅니다. 코드를 직접 붙여 넣었다면 수동 분석을 누르세요. 코드를 실행하지 않고 구조를 읽는 기능입니다.

3. 주소를 선택한 뒤 원본 위치를 눌러 코드를 확인합니다. 요청 방식(GET/POST), 로그인 필요 여부, 값이 채워져야 하는 부분을 살펴보세요.

4. 주소가 완성되어 있으면 Repeater에 요청을 준비합니다. 빈 부분이 있으면 동적 값 확정에서 실제 값을 입력한 뒤 준비하세요.

확인할 결과: 찾은 주소, 입력 이름, 코드 위치가 함께 나옵니다. 코드에 주소가 적혀 있다는 것만으로 실제로 열리거나 취약하다는 뜻은 아닙니다.

필요할 때만: 소스맵은 압축 전 코드를 찾는 단서입니다. 소스맵 탐색은 파일을 추가 요청합니다. NPM 존재 조회는 선택한 저장소에 패키지 이름을 보내 확인합니다.

다음: 요청 미관측 필터로 아직 요청하지 않은 주소를 골라 직접 확인해 보세요.

09 · 서버 정보와 점검할 경로 살펴보기

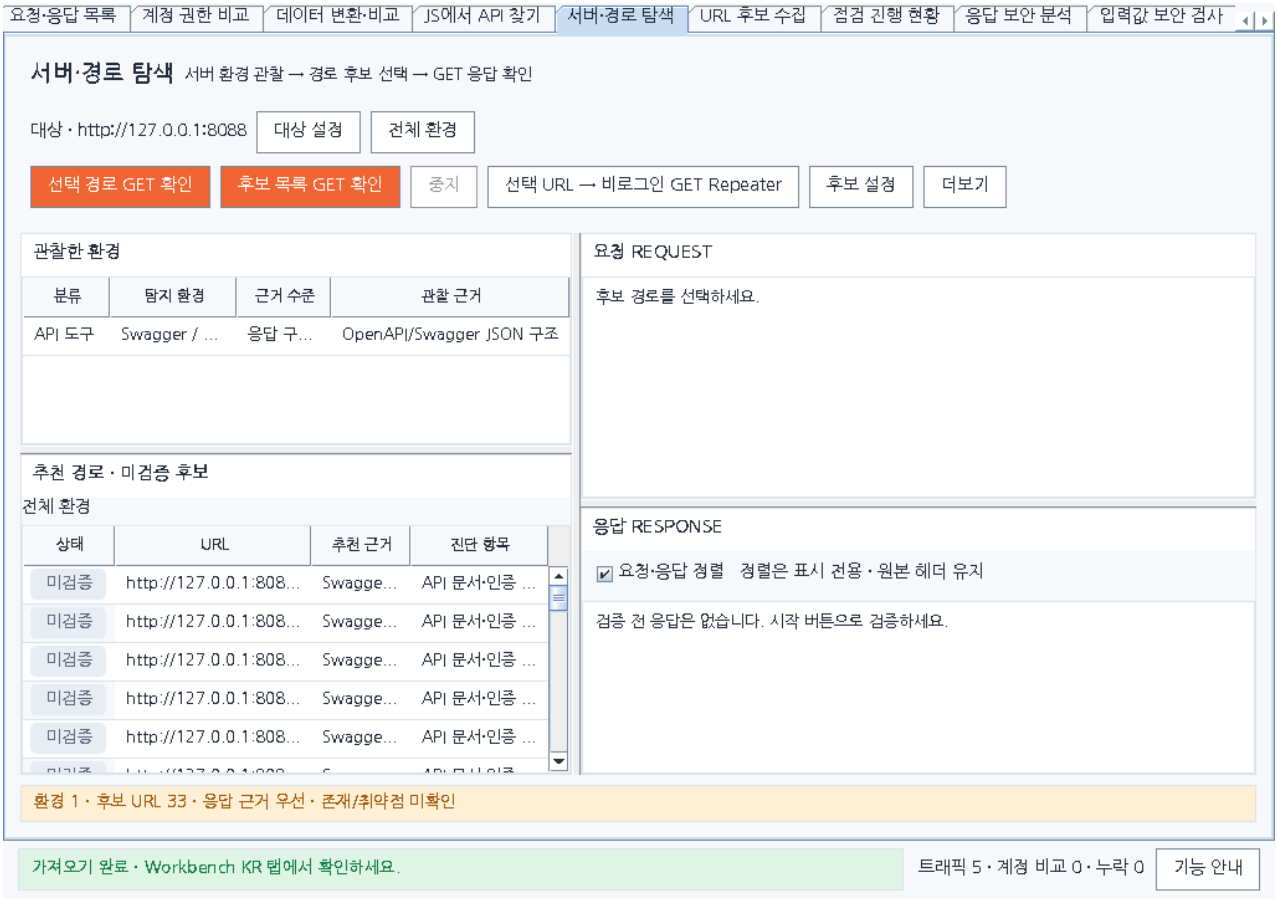


그림 6. 응답에서 찾은 서버 정보와 확인해 볼 경로를 모아 보여 줍니다.

서버의 응답에는 사용 중인 제품을 짐작할 수 있는 정보가 있습니다. 이를 바탕으로 관리 페이지나 API 문서가 있는지 찾아봅니다.

1. Burp 브라우저로 사이트를 사용한 뒤 서버·경로 탐색을 엽니다. 대상 설정에서 점검할 사이트 주소를 고르세요.

2. 기술 목록에서 제품 이름과 찾은 근거를 읽습니다. 이름이 보였다고 그 제품을 쓴다고 확정하지는 마세요.

3. 확인할 경로를 고르고 후보 설정에서 계정을 확인합니다. 로그인한 상태로 요청하려면 준비한 계정을 선택하세요.

4. 먼저 경로 하나를 선택해 선택 경로 GET 확인을 누릅니다. 실제 응답을 읽고, 없는 주소에 요청했을 때의 응답과도 비교하세요.

확인할 결과: 요청한 경로의 상태와 응답 본문이 표시됩니다. 어떤 서버는 없는 주소에도 200을 돌려줍니다. 공통 오류 페이지인지도 확인해야 합니다.

여러 경로를 확인하려면: 후보 목록 GET 확인을 사용하세요. 목록의 여러 주소에 요청을 보냅니다. 먼저 작은 목록으로 시작하는 편이 결과를 읽기 쉽습니다. 없는 주소의 응답이 일정한지 확인하는 옵션도 추가 요청을 보냅니다.

10 · 점검할 URL을 모으기

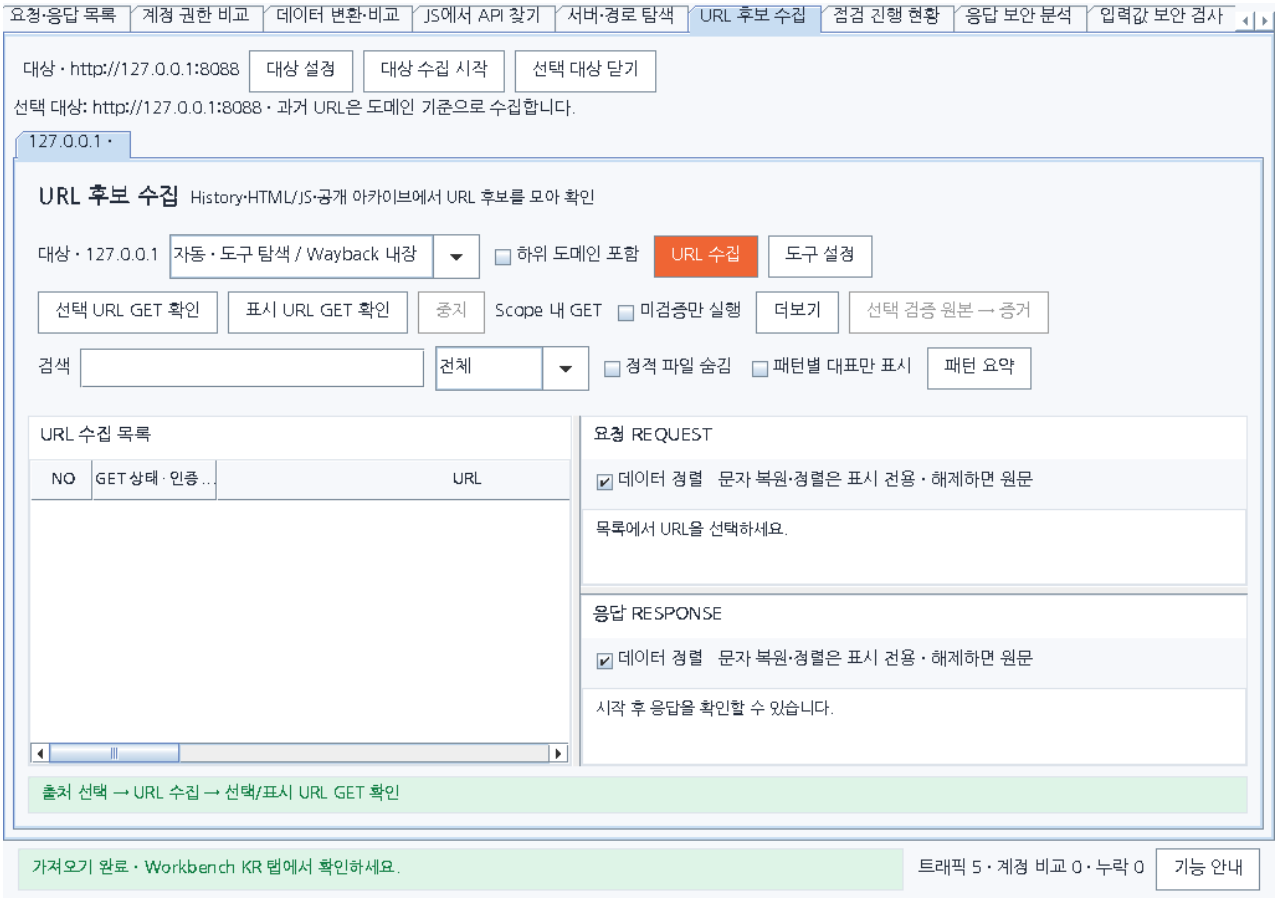


그림 7. URL을 어디에서 찾았는지, 직접 요청해 확인했는지 함께 볼 수 있습니다.

이럴 때 사용하세요: Burp에 기록된 요청이나 JavaScript 코드에서 점검할 주소를 모으고 싶을 때 사용합니다.

1. URL 후보 수집의 대상 설정에서 실습 사이트의 SCOPE를 고르고 대상 열기를 누릅니다.

2. 처음에는 수집 출처로 Burp History / JS를 선택하고 URL 수집을 누릅니다.

3. 검색어와 분류로 목록을 줄입니다. 비슷한 주소가 많으면 패턴별 대표만 표시를 선택하세요. 과거에 사용한 주소는 지금 없어졌을 수도 있습니다.

4. 확인할 주소 하나를 선택하고 선택 URL GET 확인을 누릅니다. 요청·응답이 보관되면 선택 검증 원본 → 증거로 보낼 수 있습니다.

확인할 결과: 주소를 찾은 출처와 직접 요청한 결과를 따로 확인하세요. POST로 사용하는 주소는 GET 요청만으로 정상 동작 여부를 알 수 없습니다.

실행 전 확인: URL 후보 수집 시작은 곧바로 수집을 실행합니다. 표시 URL GET 확인은 현재 보이는 주소 여러 개에 요청을 보냅니다. 삭제·수정 기능의 주소는 GET 요청으로도 데이터가 바뀔 수 있으므로 먼저 용도를 확인하세요.

필요할 때만: Wayback은 과거 웹 자료를 조회하고, waybackurls·gau는 별도로 설치하는 수집 도구입니다. URL DB를 저장해 두면 나중에 불러와 새로 발견된 주소를 비교할 수 있습니다.

11 · 아직 확인하지 않은 URL 찾기



그림 8. 주소를 찾은 상태, 실제 요청이 기록된 상태, 사람이 점검을 마친 상태를 나눠 보여 줍니다.

1. 점검 진행 현황 → URL 점검 현황에서 완료하지 않은 URL이나 입력값만 보도록 필터를 선택합니다.

2. URL을 선택하고 입력 목록을 확인합니다. 검색어, 요청 본문, 헤더, 쿠키, 경로의 숫자처럼 값이 들어가는 위치별로 표시됩니다.

3. JavaScript에서 찾은 주소라면 발견 근거 또는 소스 근거를 눌러 코드에서 어떻게 사용하는지 확인합니다.

4. 점검을 마친 입력은 입력 완료, 해당 주소의 점검을 모두 마쳤으면 URL 완료를 누릅니다. 아직 확인하지 않은 항목은 그대로 남겨 두세요.

확인할 결과: 완료 표시는 직접 눌러야 바뀝니다. 요청이 한 번 기록되었거나 검사를 실행했다는 이유만으로 점검 완료가 되지는 않습니다.

기록 보관: 기록 에서 저장·불러오기·Excel 내보내기를 사용합니다. 진행 기록을 불러와도 로그인 상태는 복원되지 않습니다.

계정별로 기록하려면: 계정별 점검 → 계정 등록에서 Bob과 Alice를 등록하세요. 해당 계정과 그 계정의 /api/auth/me 요청을 고른 뒤 트래픽 연결을 누릅니다. 이렇게 등록한 계정을 다음 쪽의 업무에 넣습니다.

12 · 해야 할 점검을 업무로 묶기

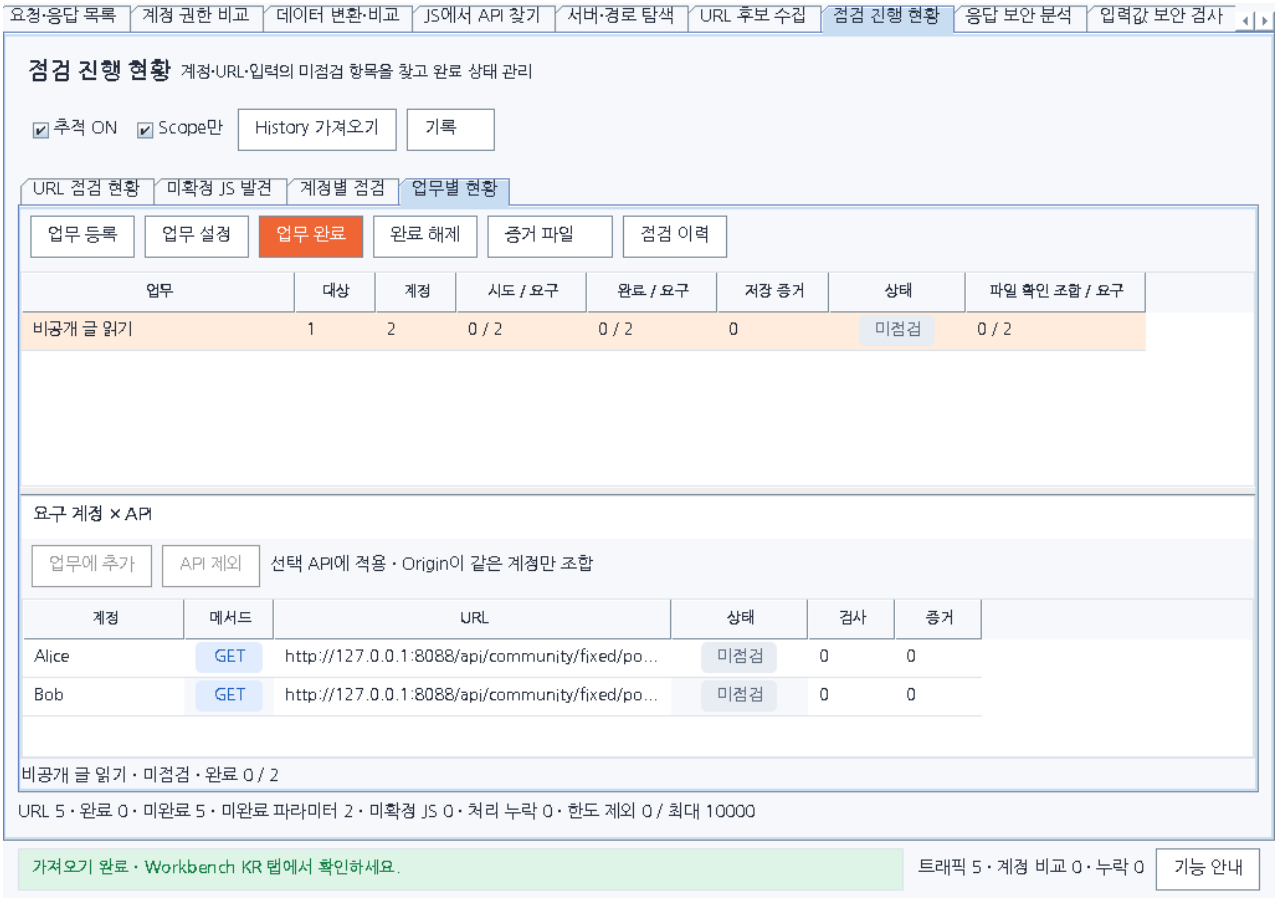


그림 9. 각 계정으로 어떤 API를 점검해야 하는지 보여 줍니다. 예시의 업무는 아직 완료하지 않았습니다.

예: '비공개 글 읽기'를 업무로 만들고 Bob과 Alice로 점검합니다. API는 글 조회 같은 기능을 처리하는 서버 주소입니다.

1. 점검 진행 현황 → 업무별 현황 → 업무 등록에서 업무 이름을 쓰고 Bob과 Alice를 선택합니다.

2. 계정별 점검 화면이나 URL 목록에서 점검할 API를 선택하고 업무에 추가를 누릅니다. 계정과 API는 같은 사이트에 등록되어 있어야 합니다.

3. 업무 설정에서 완료 기준을 정합니다. 모든 입력 수동 완료 필수는 입력을 모두 점검하도록, 모든 계정×API의 파일 확인 증거 필수는 각 계정의 점검에 증거 파일을 남기도록 하는 설정입니다.

4. 중요 입력 (쉼표 구분)에는 URL:id, BODY:ownerId처럼 값이 바뀌면 다시 볼 항목을 적습니다. 정상 요청을 한 번 보내면 확장이 현재 값을 기록합니다.

확인할 결과: Bob으로 API를 점검한 상태와 Alice로 점검한 상태가 따로 표시됩니다. 한 계정을 완료해도 다른 계정까지 완료되지 않습니다.

다음: 검사와 증거 저장 후 22쪽에서 업무를 완료하세요. 페이지 번호처럼 자주 바뀌는 값까지 중요 입력에 넣으면 불필요한 재확인이 늘어납니다.

13 · 응답에서 보안 점검할 부분 찾기



그림 10. 이미 받은 응답에서 확인할 부분을 찾습니다. 이 기능은 추가 요청을 보내지 않습니다.

이미 받은 응답에서 오류 메시지, 쿠키 설정, 응답 헤더를 살펴봅니다.

1. 실습 사이트를 이용한 뒤 응답 보안 분석 → 응답 관찰을 엽니다.

2. 결과를 하나 선택하고 규칙, 근거 위치, 관찰 근거를 읽습니다. 아래 영향 URL 목록에는 같은 내용이 발견된 주소가 표시됩니다.

3. 실제 응답에도 그 헤더나 문구가 있는지 확인하세요. 어떤 요청에서 나왔는지, 어떤 문제가 되는지도 살펴봅니다.

4. 원본 요청·응답이 연결되어 있으면 선택 관찰 → 증거를 눌러 증거 묶음으로 보냅니다.

확인할 결과: 자동으로 찾은 내용은 더 확인할 단서입니다. 대표 요청 하나를 증거로 보내도 목록의 모든 주소를 확인한 것은 아닙니다.

예: 오류 클래스 이름도 실습용 문구일 수 있습니다. 실제 오류가 난 상황과 외부에 드러난 정보를 확인한 뒤 결과를 적으세요.

원본이 없으면: 같은 동작을 다시 수행해 요청·응답을 기록합니다. 크기가 너무 큰 응답은 원본이 보관되지 않을 수 있습니다.

14 · API 문서를 보고 요청 만들기



그림 11. API 문서에 적힌 주소와 입력값을 보여 줍니다. 실제 요청 기록이 있는지도 함께 확인할 수 있습니다.

OpenAPI/Swagger 문서에 적힌 주소와 입력값으로 점검용 요청을 만듭니다.

1. Burp 브라우저에서 실습 주소 /v3/api-docs를 엽니다. Workbench가 이 문서의 응답을 읽습니다.

2. 응답 보안 분석 → API 문서에서 메서드와 경로를 선택합니다. 관찰 결과에서 해당 주소로 보낸 요청이 기록되어 있는지 확인하세요.

3. Repeater 초안을 누르고 실제 값을 입력합니다. 예를 들어 /posts/{id}의 {id}를 바꿔 /posts/102로 입력합니다.

4. Repeater 초안 준비를 누른 뒤 Burp Repeater에서 로그인 쿠키, 본문, 입력값을 확인하고 직접 전송합니다.

확인할 결과: 문서에 적힌 메서드와 입력 이름을 사용한 요청이 만들어집니다. 로그인 정보와 쿼리의 실제 값은 자동으로 복사하지 않으므로 직접 채워야 합니다.

확인할 점: 문서가 오래되면 실제 사용 방법과 다를 수 있습니다. 글 번호를 채웠더라도 그 글의 소유자와 접근 권한은 별도로 확인하세요.

파일 업로드 요청: 파일과 텍스트를 함께 보내는 multipart 요청은 문서만으로 만들지 않습니다. 브라우저에서 실제 업로드한 요청을 가져와 사용하세요.

15 · 저장한 값이 나중에 어디에 나오는지 확인하기

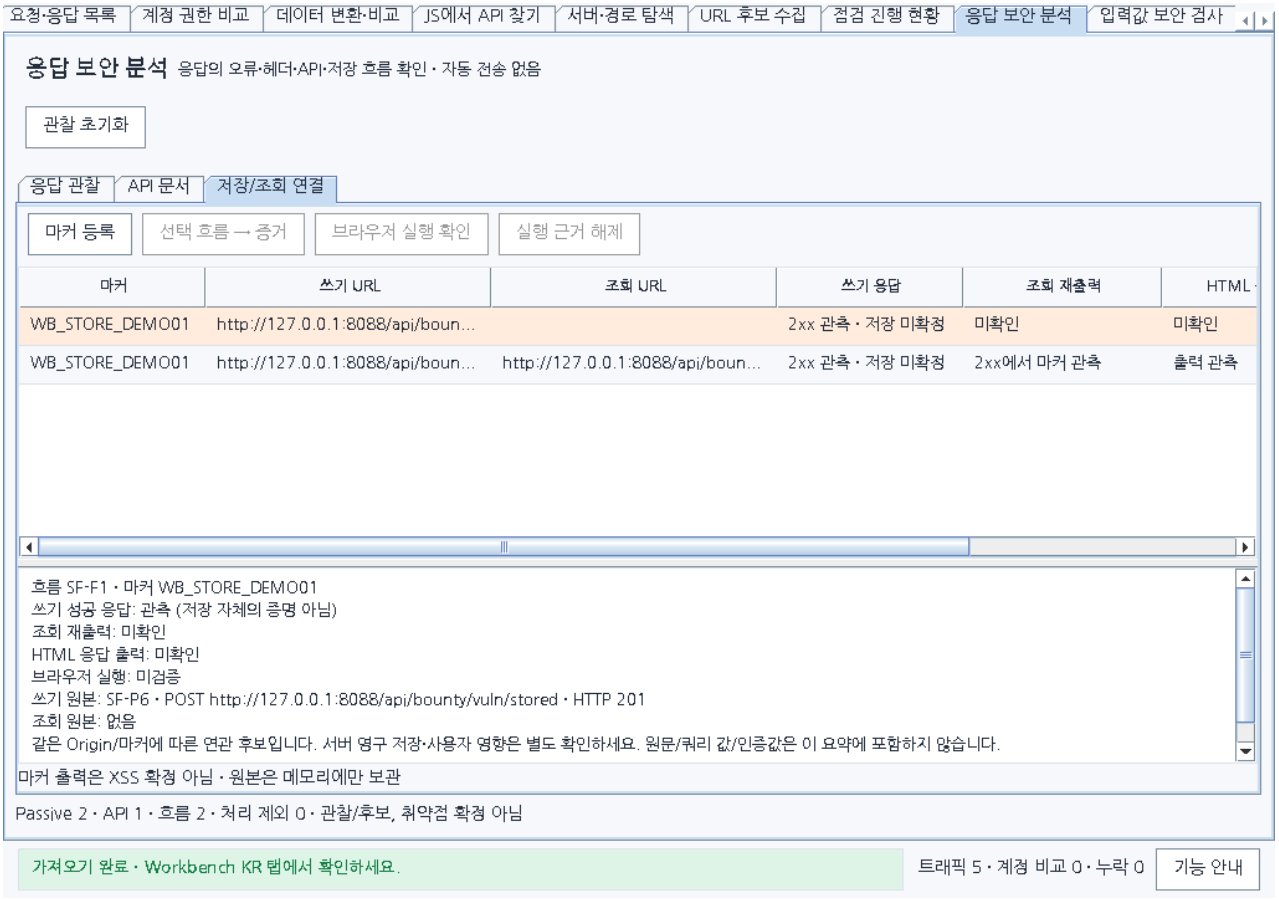


그림 12. 같은 표시 문자열이 저장 후 조회할 때 다시 나오는 예시입니다. 브라우저에서 스크립트가 실행되었는지는 확인하지 않았습니다.

게시글처럼 저장한 값이 나중에 어떻게 표시되는지 확인합니다.

1. 응답 보안 분석 → 저장/조회 연결 → 마커 등록을 누릅니다. WB_STORE_DEMO01처럼 구별하기 쉬운 표시 문자열인 '마커'를 등록합니다.

2. 실습 /bounty-lab에서 저장할 내용에 같은 문자열을 넣고 저장합니다. 목록·상세 화면과 저장 응답에 나온 조회 주소를 차례로 엽니다.

3. 쓰기 응답은 저장 직후의 응답, 조회 재출력은 다시 읽었을 때 마커가 나왔는지를 뜻합니다. HTML 출력과 브라우저 실행도 확인하세요.

4. 선택 흐름 → 증거를 누르면 저장할 때와 조회할 때의 요청·응답을 함께 보낼 수 있습니다.

확인할 결과: 같은 문자열이 다시 보인다고 스크립트가 실행된 것은 아닙니다. 텍스트로 보이는 것, HTML에 들어간 것, 실제로 실행된 것을 구별하세요.

실행을 직접 확인했다면: 브라우저 실행 확인으로 개인정보를 가린 PNG/JPEG를 첨부합니다. 이미지가 있다는 이유만으로 실행을 확인했다고 표시하지 마세요.

다음: 저장·조회가 바뀌면 첨부 이미지도 같은 상황을 보여 주는지 다시 확인하세요.

16 · 데이터 변환과 응답 비교하기

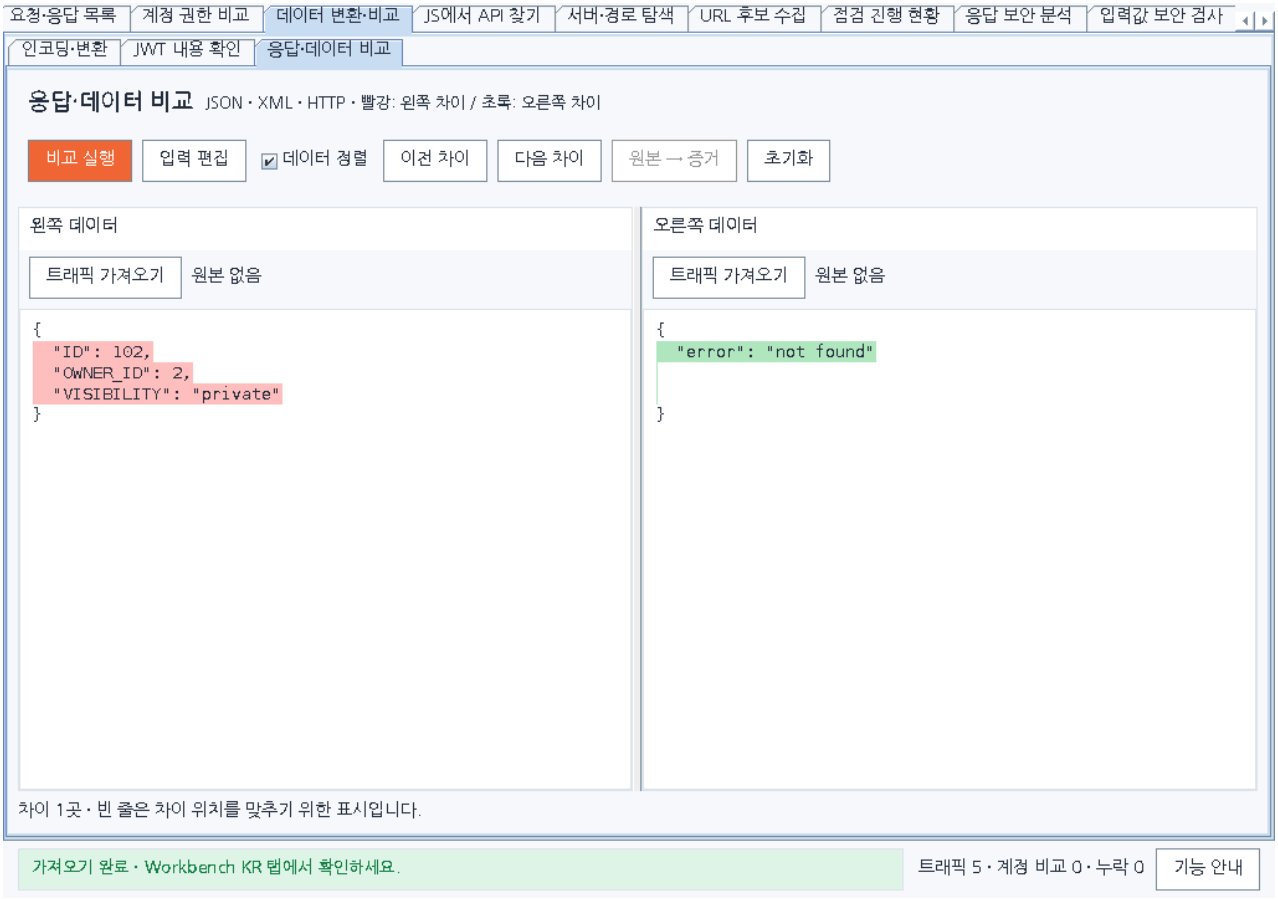


그림 13. 왼쪽과 오른쪽 데이터를 비교합니다. 직접 붙여넣은 텍스트에는 원본 요청·응답이 연결되지 않습니다.

데이터 변환·비교에는 세 가지 도구가 있습니다. JWT는 회원 정보 등을 담아 주고받는 토큰입니다.

하고 싶은 일	이렇게 사용하세요
URL·Base64·Hex 변환, 해시 계산, 압축 처리	인코딩·변환에서 값을 넣고 작업을 골라 변환을 누릅니다. 다시 변환하려면 출력 → 입력을 누릅니다.
JWT에 담긴 내용 읽기	JWT 내용 확인에서 선택 요청에서 가져오기를 누르거나 토큰을 붙여넣고 JWT 디코딩을 누릅니다. 변조 여부를 확인하는 서명 검증은 하지 않습니다.
두 응답의 차이 보기	응답·데이터 비교를 엽니다. 첫 요청을 선택해 왼쪽 트래픽 가져오기, 다른 요청을 선택해 오른쪽 트래픽 가져오기를 누른 뒤 비교 실행을 누릅니다.

예: Bob이 글을 읽은 응답과 Alice가 차단된 응답을 비교합니다. 원본을 양쪽에 가져왔다면 원본 → 증거로 두 요청·응답을 함께 보냅니다.

확인할 점: 가져온 내용을 편집하면 해당 원본과의 연결이 끊깁니다. 비교 표시는 입력 64 KiB·1,500줄까지이며, 연결할 원본은 요청과 응답을 합쳐 128 KiB 이하여야 합니다.

JWT의 role 값이 바뀌어도 서버의 권한이 바뀐다는 뜻은 아닙니다. 실제 응답을 확인하세요.

17 · 점검 결과를 증거 묶음으로 모으기

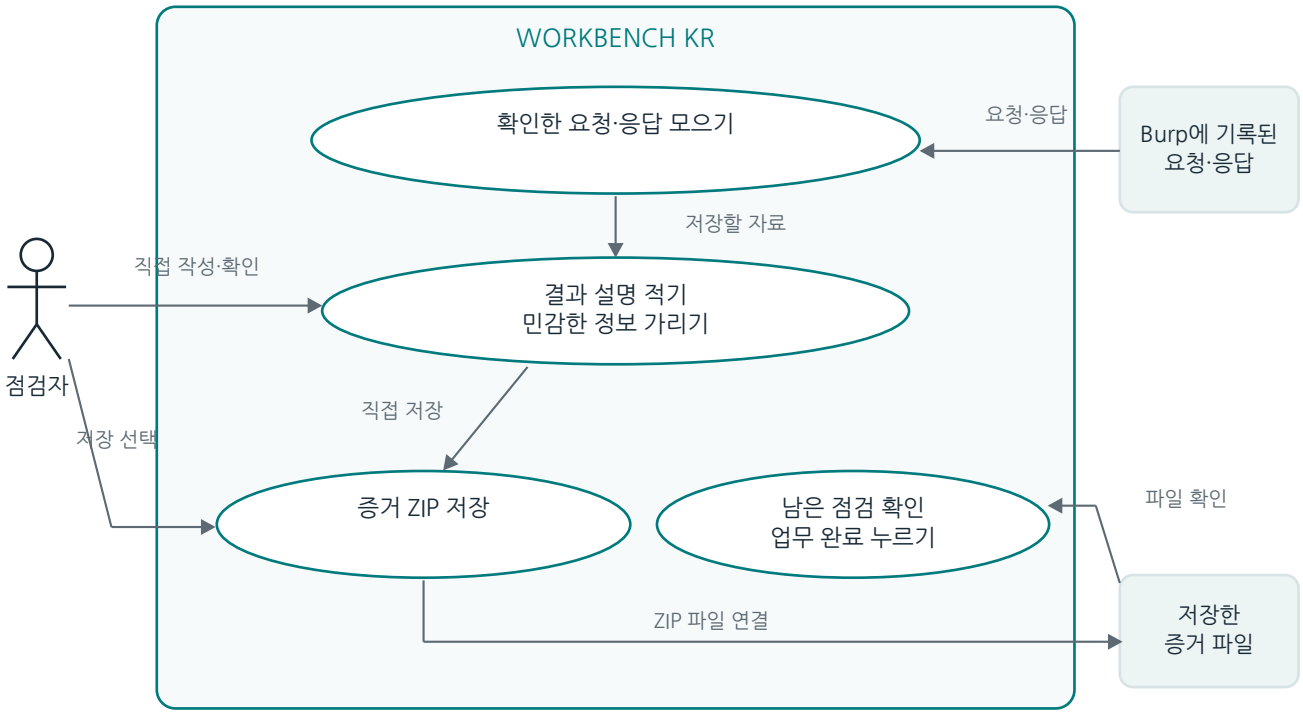


그림 14. 각 검사에서 확인한 요청·응답을 증거로 모아 저장하고, 저장한 파일을 업무에 연결합니다.

예: Bob의 정상 조회, Alice의 타인 글 조회, 수정 후 Alice의 차단 요청을 한 ZIP에 담습니다. 다른 사람이 따라 할 수 있도록 각 요청의 순서를 적습니다.

1. 계정 비교·입력값 검사·응답 분석에서 필요한 요청·응답을 증거 묶음으로 보냅니다.

2. 요청 여러 개를 같은 순서로 보내야 한다면 다음 쪽의 여러 요청 재현을 사용합니다.

3. 누가 무엇을 볼 수 있었는지, 재현 순서는 무엇인지 적습니다. 가림 미리보기에서 로그인 정보나 개인정보가 남아 있는지 확인합니다.

4. ZIP을 저장하고 파일이 만들어졌는지 확인합니다. 업무에 연결한 뒤 아직 점검하지 않은 계정이나 입력값을 확인하세요.

검사 결과와 업무 완료는 다릅니다: 결과는 요청을 보내 확인한 내용입니다. 업무 완료는 필요한 계정·입력값·증거를 사람이 모두 확인했다는 표시입니다. 검사 결과나 파일이 생겨도 업무는 자동 완료되지 않습니다.

다음: 여러 요청을 순서대로 보내는 방법은 19쪽, 증거 ZIP 저장은 20쪽, 업무 완료는 22쪽에서 설명합니다.

18 · 여러 요청을 순서대로 실행하기

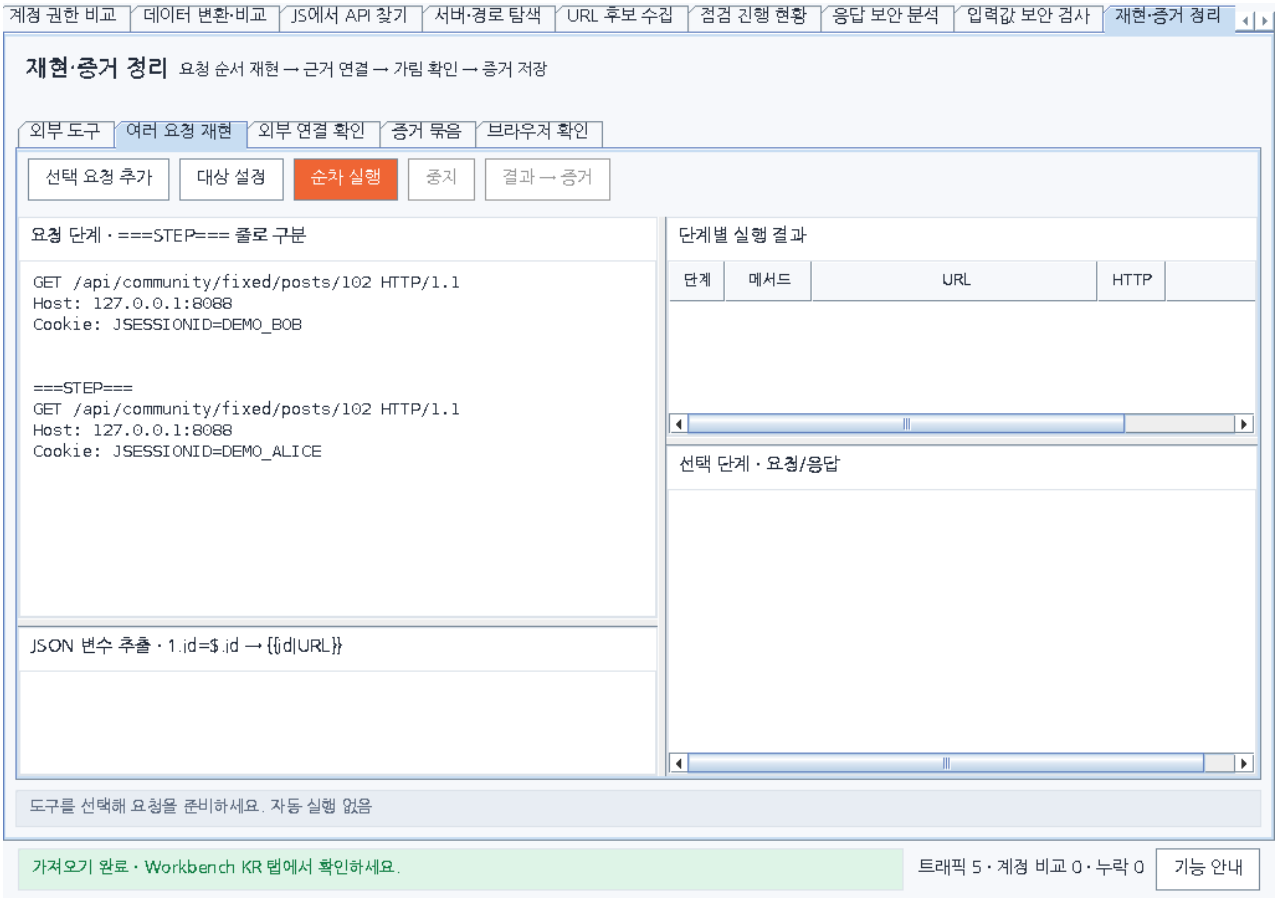


그림 15. 여러 요청을 순서대로 준비하고 실행하는 화면입니다.

게시물을 만든 뒤 새 글의 ID로 조회하는 것처럼, 여러 요청을 이어서 보낼 때 사용합니다.

1. 요청·응답 목록에서 첫 요청을 고릅니다. 재현·증거 정리 → 여러 요청 재현을 열고 선택 요청 추가를 누르세요. 다음 요청도 같은 방법으로 추가합니다.

2. 대상 설정에서 사이트 주소(Origin), 총 요청 한도, 각 단계의 예상 응답을 확인하세요. 게시물 등록처럼 데이터를 바꾸는 요청은 쓰기 단계 실행 허용을 선택해야 실행됩니다.

3. 앞선 응답의 ID가 필요하면 JSON 변수 추출 칸에 1.id=$.id를 입력합니다. 이는 '1단계 응답의 id 값을 보관하라'는 뜻입니다. 다음 요청의 URL에 {{id|URL}}을 넣으면 그 값을 사용합니다.

4. 순차 실행을 누르고 단계별 요청과 응답을 확인하세요. 실행이 끝나면 결과 → 증거로 결과를 옮깁니다.

확인할 결과: 예상한 응답을 받지 못하거나 필요한 값을 찾지 못하면 다음 단계는 실행하지 않습니다. 중단된 단계의 이유부터 확인하세요.

처음 연습할 때: GET 요청 두 개로 순서를 익히세요. 최대 8단계이며, 같은 사이트의 SCOPE 안에서 실행합니다. 다른 주소로 이동하라는 응답은 따라가지 않습니다. 구분 줄은 ===STEP===입니다. JSON에 값을 넣을 때는 {{id|JSON}}, 변환 없이 넣을 때만 {{id|RAW}}를 씁니다.

19 · 확인한 결과를 ZIP 파일로 저장하기

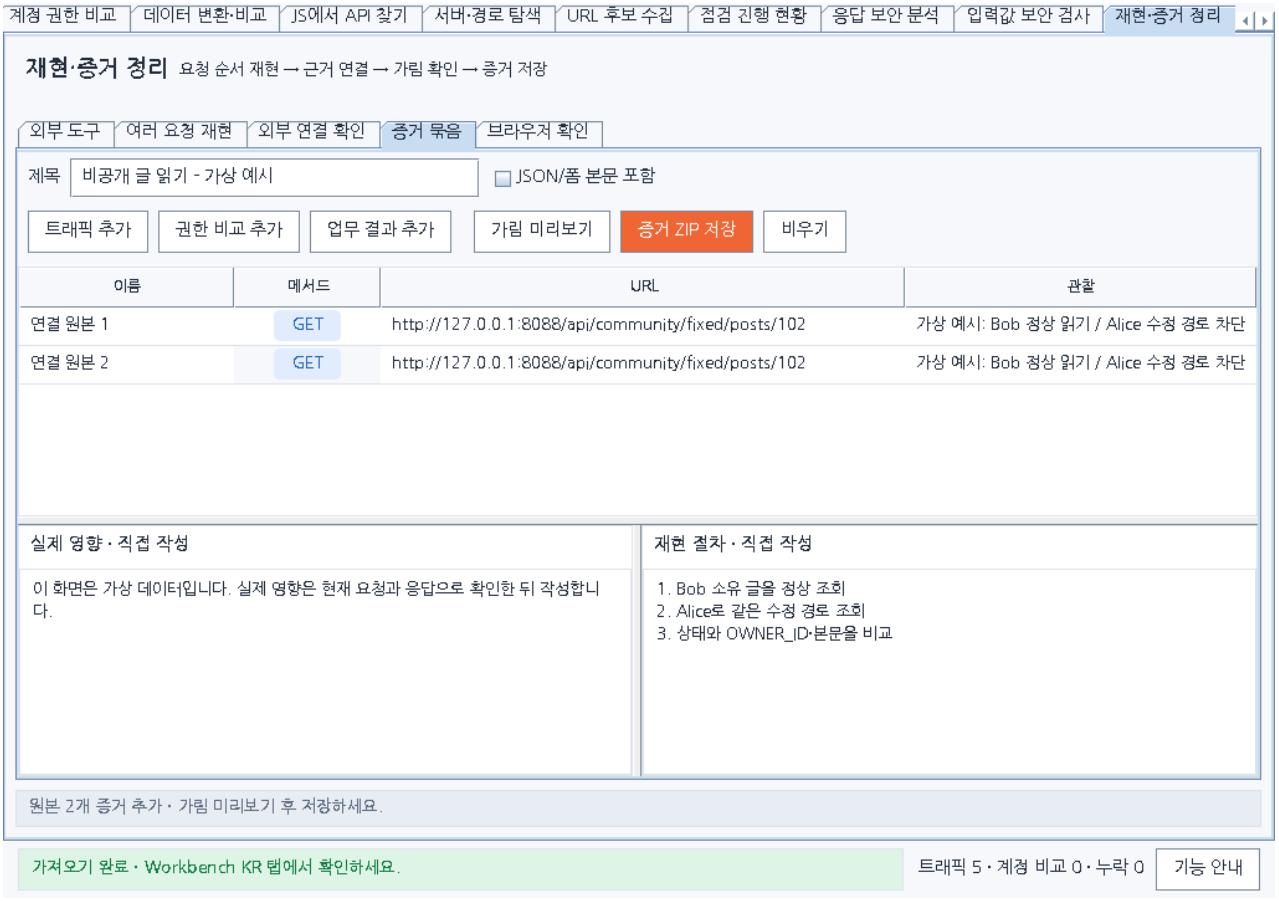


그림 16. 요청·응답을 모으고 설명을 적어 ZIP으로 저장하는 화면입니다.

요청·응답과 설명을 함께 저장해, 다른 사람도 결과를 확인할 수 있게 합니다.

1. 재현·증거 정리 → 증거 묶음을 엽니다. 트래픽 추가, 권한 비교 추가, 업무 결과 추가로 결과를 모으세요. 다른 화면에서 보낸 결과도 이곳에 나타납니다.

2. 제목에는 발견한 문제를 한 문장으로 씁니다. 영향에는 '누가 어떤 정보를 볼 수 있었는지', 재현 절차에는 '어떤 계정으로 무엇을 했는지'를 순서대로 적으세요.

3. 가림 미리보기에서 로그인 정보와 민감한 내용이 가려졌는지 확인하세요. 직접 쓴 설명도 읽어 보세요. 요청 본문이 필요할 때만 JSON/폼 본문 포함을 선택합니다.

4. 증거 ZIP 저장을 누르고, 선택한 위치에 파일이 생겼는지 확인하세요.

확인할 결과: ZIP에 요청·응답과 작성한 설명이 들어갑니다. 화면 목록에 추가하는 것만으로 파일이 저장되지는 않습니다.

저장 한도: 요청 32개와 이미지 1장까지 넣을 수 있습니다. 이미지가 더 필요하면 현재 묶음을 저장하고 비운 뒤 새로 만드세요. 로그인 정보가 가려진 파일로는 같은 로그인 상태를 재현할 수 없습니다.

다음: 22쪽에서 저장한 파일을 확인하고 업무를 완료합니다.

20 · 외부 연결과 브라우저 결과 확인하기

대상의 응답만으로 결과를 알 수 없을 때 사용합니다. 예를 들어, 입력한 주소로 실제 연결이 있었는지 확인하는 방법을 OAST라고 합니다. Collaborator는 이를 확인할 주소를 발급하고 연결 기록을 보여주는 Burp 서비스입니다.

하고 싶은 일	사용 방법	확인할 내용
확인용 주소 만들기	요청 선택 → 재현·증거 정리 → 외부 연결 확인 → 콜백 ID 발급	주소가 만들어집니다. 그 주소를 넣은 요청은 직접 준비하고 전송해야 합니다.
연결 기록 확인하기	콜백 조회	연결 종류·시각·ID를 보고, 방금 보낸 요청과 관련된 기록인지 확인합니다.
다른 OAST 서비스의 기록 가져오기	화면에 적힌 형식으로 붙여넣기 → 외부 콜백 결과 가져오기	ID·요청 방식·URL을 확인해 같은 테스트의 결과인지 봅니다.
다른 Burp 확장 사용하기	외부 도구에서 도구 선택 → 선택 요청 → Repeater	해당 도구를 별도로 설치하고 직접 실행합니다. 발견한 입력 이름은 진행 기록으로 옮길 수 있습니다.
브라우저 화면 첨부하기	브라우저 확인 → 직접 재현 → 브라우저 증거 이미지 첨부	민감한 내용을 가린 PNG/JPEG를 증거 묶음에 넣습니다.

기록 읽기: '콜백'은 확인용 주소에 연결이 있었을 때 남는 기록입니다. 주소 조회(DNS) 기록만으로 서버에서 코드가 실행됐다고 결론 내릴 수는 없습니다. 연결 종류와 실제로 확인한 결과를 함께 적으세요.

준비할 것: Collaborator를 사용할 수 있는 Burp 환경이 필요합니다. 다른 확장의 설치나 실행, 브라우저에서의 재현은 직접 해야 합니다. 이 안내서의 그림은 실제 연결이나 브라우저 실행을 확인한 결과가 아닙니다.

21 · 점검을 마치고 다음에 이어 하기

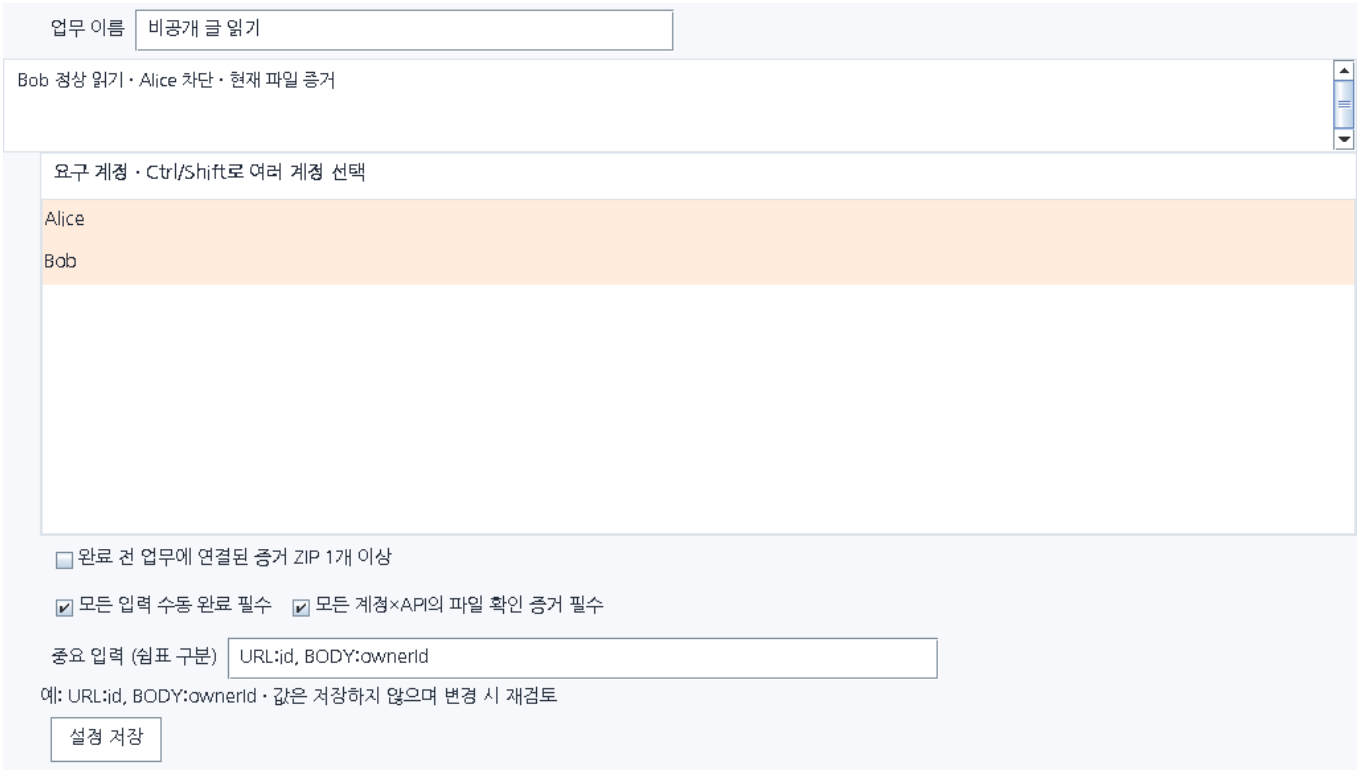


그림 17. 업무를 마치기 전에 확인할 계정, 입력값, 증거를 정하는 화면입니다.

검사 결과를 직접 검토한 뒤 완료 표시를 합니다.

1. 점검 진행 현황 → 계정별 점검에서 점검한 계정과 API를 고르세요. 확인한 입력에는 입력 완료 / 해제, URL에는 URL 완료를 누릅니다.

2. 업무별 현황에서 필요한 계정을 모두 점검했는지 확인하세요. Bob과 Alice를 점검하기로 했다면 Bob만 완료해서는 업무를 마칠 수 없습니다.

3. 증거 파일 → 모든 증거 재검증을 눌러 저장한 ZIP이 그대로 있는지 확인하세요. 파일을 옮겼다면 증거 ZIP 재연결로 다시 선택합니다.

4. 점검과 증거 저장을 마쳤으면 업무 완료를 누르세요. 계정별 완료만으로 업무 전체가 자동 완료되지는 않습니다.

확인할 결과: 업무 설정에서 정한 계정·입력·증거가 준비되면 완료할 수 있습니다. 권한, 조직, 중요한 입력값이나 대상이 바뀌면 다시 확인해야 할 수 있습니다.

다음에 이어 할 때: 진행 기록(JSON)을 불러와도 로그인 상태와 증거 파일 위치는 복원되지 않습니다. 다시 로그인해 계정의 요청을 연결하고, ZIP 파일도 다시 선택하세요. 중요한 입력값도 다시 확인해 비교 기준을 잡아야 합니다. 파일 상태는 마지막으로 직접 확인한 결과입니다.

22 · 결과를 다른 사람이 이해하게 쓰기

아래는 작성 예시입니다. 실제로 확인한 요청·응답과 계정 정보를 바탕으로 내용을 바꿔 쓰세요.

항목	작성 예
제목	일반 회원이 다른 회원의 비공개 글을 읽을 수 있습니다.
점검 조건	로컬 실습의 vuln 경로에서 Bob의 비공개 글 102를 Alice로 조회했습니다.
재현 순서	Bob으로 글을 조회합니다. Alice로 같은 글을 조회한 뒤, fixed 경로에서도 비교합니다.
예상한 결과 / 실제 결과	작성자만 읽을 수 있어야 합니다. Alice의 응답에도 Bob의 글이 나타났습니다.
영향	다른 회원의 비공개 정보가 노출됩니다.
첨부할 자료	계정별 요청·응답, 점검 시각, 저장한 ZIP 파일
확인하지 않은 부분	실제 운영 서비스의 영향, 운영 데이터, 별도 브라우저 실행

진행이 막히면 이렇게 확인하세요

문제	먼저 확인할 내용
요청 목록이 비어 있습니다.	응답을 받았는지, 수집이 켜져 있는지 확인하세요. 검색이나 Scope만 필터도 확인합니다.
버튼을 누를 수 없습니다.	행을 선택했는지, 요청·응답이 남아 있는지, 검사가 실행 중인지 확인하세요.
두 계정의 결과가 같습니다.	등록한 쿠키와 로그인 사용자를 확인하세요. 비교 요청과 예상 권한도 확인합니다.
200 응답인데 내용이 이상합니다.	본문이 로그인 화면이나 오류 메시지인지 확인하세요. 없는 주소에도 200을 반환하는 사이트가 있습니다.
증거를 저장할 수 없습니다.	요청을 추가하고 검사를 마쳤는지 확인하세요. 가림 미리보기와 저장 위치도 확인합니다.

화면 아래 기능 안내에서도 사용 순서를 확인할 수 있습니다. 결과가 달라지면 계정과 입력값이 이전과 같은지부터 확인하세요.

23 · 익숙한 기능의 새 이름 찾기

화면 이름만 보고도 용도를 알 수 있도록 이름을 바꿨습니다. 예전 이름이 익숙하다면 아래 표에서 찾아보세요.

이전 이름	0.25.0 이름	하는 일
트래픽	요청·응답 목록	사이트가 주고받은 요청과 응답을 봅니다.
권한 비교	계정 권한 비교	같은 요청을 서로 다른 계정으로 보내 비교합니다.
데이터 도구	데이터 변환·비교	데이터를 변환하고 JWT 내용이나 두 응답의 차이를 봅니다.
JS 추출	JS에서 API 찾기	JavaScript에서 API 주소와 입력 이름을 찾습니다.
환경 탐색	서버·경로 탐색	서버 종류의 단서를 찾고 주소를 확인합니다.
URL 수집	URL 후보 수집	점검할 URL을 여러 곳에서 모읍니다.
활동 추적	점검 진행 현황	어떤 URL과 계정을 점검했는지 기록합니다.
응답 분석	응답 보안 분석	응답의 보안 단서, API 문서, 저장한 값의 조회 결과를 봅니다.
페이로드 검사	입력값 보안 검사	입력값을 바꿔 보내고 응답을 비교합니다.
점검 지원	재현·증거 정리	요청을 순서대로 실행하고 결과를 저장합니다.

하위 화면의 새 이름: 변환 → 인코딩·변환, JWT → JWT 내용 확인, 비교 → 응답·데이터 비교, Passive 관찰 → 응답 관찰, 업무 흐름 → 여러 요청 재현, OAST 연결 → 외부 연결 확인입니다.

빠르게 찾기: 화면 아래 기능 안내에서 기능을 고른 뒤 이 기능 열기를 누르세요. 안내를 열거나 화면을 이동하는 것만으로 검사가 실행되지는 않습니다.

안내서 기준: Workbench 0.25.0과 실습 사이트 3.5.0입니다. 그림은 사용법을 설명하려고 예제 데이터를 넣어 만든 화면입니다. 실제 Burp에서 점검을 마친 결과를 캡처한 그림은 아닙니다.